CLEAR: Causal Context-Based Agentic Reasoning for Vulnerability Detection*

Sungju Yun†
Hanyang University
Ansan, Republic of Korea
tjdwn77777@hanyang.ac.kr

Sijune Hwang†
Hanyang University
Ansan, Republic of Korea
ghkdtlwns987@hanyang.ac.kr

Yeonjoon Lee‡
Hanyang University
Ansan, Republic of Korea
yeonjoon@hanyang.ac.kr

Kyungtae Kang
Hanyang University
Ansan, Republic of Korea
ktkang@hanyang.ac.kr

Sungbin Park
Hanyang University
Ansan, Republic of Korea
pbt98@hanyang.ac.kr

arXiv:2608.03134v2 [cs.CR] 6 Oct 2026

Abstract

Detecting source code vulnerabilities is increasingly difficult as modern security flaws are rooted in complex causal dependencies between execution flows, control conditions, and program states. Despite recent advances in Large Language Models (LLMs) and multi-agent frameworks, existing approaches primarily address superficial similarities between benign and vulnerable functions while failing to capture the complex causal dependencies inherent in security flaws. To address these limitations, we propose **Causal Context-based Agentic Reasoning (CLEAR)**, a novel multi-agent vulnerability detection framework integrated with a causal knowledge graph. CLEAR systematically constructs a **Vulnerability Causal Knowledge Graph (VCKG)** that models the causal chains between entrypoints, preconditions, root causes, and fix intents across vulnerability instances. Leveraging this structured knowledge, four specialized agents including the Collector, Claim, Critic, and Judge collaboratively verify vulnerability hypotheses through retrieved causal contexts. Experimental results on C/C++ and Java vulnerability benchmarks demonstrate that CLEAR improves Pair-Correct (P-C) performance by 130.7% and 71.56% over state-of-the-art approaches, respectively, demonstrating the effectiveness of causal knowledge graph–guided reasoning for automated vulnerability detection.

CCS Concepts

• **Security and privacy** → *Software security engineering*.

Keywords

Vulnerability Detection, Knowledge Graph, Retrieval Augmented Generation(RAG), Multi-Agent

1 Introduction

As modern software systems grow in scale and complexity, accurately identifying and classifying vulnerabilities within source code has become a fundamental task for ensuring system security. While manual inspection by security professionals provides high-quality results, it is difficult to scale across massive codebases due to the significant time and human resources required [17]. Moreover, the increasing complexity of vulnerabilities makes it challenging to maintain consistent detection accuracy through manual review alone. In response, various automation studies have been conducted, ranging from traditional static and dynamic analysis [11, 18] to deep learning-based methods [3, 25, 27, 29, 31, 42, 43]. More recently, with the remarkable success of Large Language Models (LLMs) in various NLP tasks [1, 19, 23, 36, 40], researchers have increasingly explored their application to automated vulnerability detection [30, 32, 34, 41].

Despite these advances, accurately distinguishing vulnerable code from its non-vulnerable counterparts remains a non-trivial challenge. In practice, many software vulnerabilities in real-world scenarios arise from subtle differences between benign and vulnerable functions, where the core flaw is often hidden behind nearly identical syntactic structures[33]. Recent benchmarks such as PrimeVul[5] have been specifically curated to reflect this reality by providing datasets where the functional differences between benign and vulnerable code pairs are extremely subtle. However, existing models often exhibit significant performance degradation when evaluated on such paired instances because they struggle to capture these fine-grained distinctions and fail to precisely differentiate a secure implementation from its flawed counterpart. This performance gap in challenging benchmark settings suggests that robust vulnerability detection requires a deep analysis of the structural causal nuances that define a security flaw rather than relying solely on high-level semantic understanding.

To address this issue, recent frameworks such as VulTrial [38] have introduced multi-agent debate mechanisms that emulate courtroom style reasoning, aiming to mitigate overconfidence, hallucination, and the lack of verification observed in single-agent approaches [7, 13, 21, 35]. By enabling agents to generate competing hypotheses and critically examine each other's claims, collaborative argumentation helps surface semantic inconsistencies between similar code variants. However, these multi-agent approaches still

*This research was supported by the MSIT(Ministry of Science and ICT), Korea, under the Convergence security core talent training business support program(IITP-2024-RS-2024-00423071, 10%) supervised by the IITP(Institute of Information & Communications Technology Planning & Evaluation), This work was supported by the National Research Foundation of Korea(NRF) grant funded by the Korea government(MSIT)(RS-2024-00356926, 50%), and This work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP) grant funded by the Korea government(MSIT) (RS-2024-00341722, Development of Cyber Resilience Method for Intelligent Service Robots, 40%).
†Both authors contributed equally to this research.
‡Corresponding author.

fundamentally rely on the internal pre-trained knowledge of LLMs, making them inherently susceptible to reasoning degeneration and bias [15, 16]. While they leverage the code understanding capabilities of LLMs, they lack an explicit mechanism to resolve the complex causal dependencies that actually define a vulnerability, often leading to false positives when encountering subtle code similarities.

To overcome these limitations, we propose **CLEAR (Causal Context-based Agentic Reasoning)**, a framework designed to perform vulnerability detection by grounding multi-agent reasoning in structured causal contexts. CLEAR moves beyond simple semantic pattern matching by utilizing the underlying causal dependencies such as the relationships between entrypoints, preconditions, and root causes to resolve the ambiguity between similar code variants. To support this process, we introduce the **Vulnerability Causal Knowledge Graph (VCKG)**, which systematically models the causal chains of security flaws across diverse vulnerability instances. By representing vulnerabilities as structured causal paths rather than fragmented code snippets, VCKG provides an external knowledge base that constrains the reasoning process, allowing LLMs to focus on the logical mechanisms of an exploit rather than superficial code similarities.

We conduct comprehensive evaluations against both single-agent and multi-agent baselines. For single-agent methods, we consider deep learning–based models such as CodeBERT [8] and UniXCoder [12], as well as LLM-based approaches following the prompting strategy of Ding et al. [5]. For multi-agent frameworks, we benchmark against GPTLens [14] and the state-of-the-art model VulTrial [38]. Evaluation on C/C++ and curated Java-Pair datasets shows that CLEAR outperforms state-of-the-art models by 130.7% and 71.56%, respectively, in the Pair-Correct (P-C) metric. These results empirically validate that structural causal reasoning is essential for capturing the complex nature of security vulnerabilities and effectively distinguishing them from benign code. The primary contributions of this paper are as follows:

- **Design of the CLEAR Framework:** We develop a causal knowledge-based multi-agent analysis framework that utilizes the causal context retrieved from VCKG as a reasoning constraint to perform multi-perspective vulnerability verification.
- **VCKG Modeling:** We propose the first Vulnerability Causal Knowledge Graph (VCKG), which organizes causal relationships among related vulnerability types into a structured format optimized for LLM reasoning.
- **Empirical Validation:** We demonstrate the effectiveness of structural causal reasoning by achieving up to a 130% performance improvement over existing SOTA models across diverse programming language datasets, including C/C++ and Java.

2 Methodology

In this section, we present the overall architecture of CLEAR, a framework designed to perform vulnerability detection through multi-agent reasoning guided by structured causal contexts retrieved from a Vulnerability Causal Knowledge Graph (VCKG). The framework consists of two primary processes: (1) VCKG Construction and (2) Multi-Agent Reasoning. In the VCKG construction phase, the system operates in an offline environment, taking raw vulnerability data as input to map the complex causal chains and propagation paths of vulnerability data. Subsequently, during the Multi-Agent Reasoning phase, CLEAR leverages the structured causal contexts retrieved from the VCKG to support hypothesis generation, adversarial verification, and final decision making through collaborative interaction among specialized agents, enabling vulnerability detection.

2.0 Design of Vulnerability Causal Knowledge Graph

Vulnerability detection fundamentally requires understanding the causal chain from an external trigger to a logical failure. However, existing LLM-based approaches often rely on internally learned statistical patterns and may therefore struggle to explicitly capture the underlying causal structure of vulnerability formation [27, 29]. Incorporating structured context through retrieval can support LLM reasoning by grounding the inference process in explicitly retrieved vulnerability-related contexts [9, 26], thereby reducing reliance on implicit statistical associations. However, conventional retrieval strategies typically rely on flat semantic similarity or chunk-level matching, which may introduce irrelevant context or fail to preserve the essential causal relationships required for reliable vulnerability reasoning [37].

To address these challenges, we propose the Vulnerability Causal Knowledge Graph (VCKG), which organizes vulnerability data into structured causal components, including execution entrypoints, triggering pre conditions, root causes, and fix intents. This representation explicitly captures causal dependencies involved in vulnerability formation and provides structured context to support reasoning in retrieval-based LLM frameworks. At a granular level, VCKG implicitly models fine-grained vulnerability characteristics at the attribute level by systematic mapping: for instance, operational constraints such as "improper input handling" map directly to a Precondition node as a missing environmental safe state, while specific functional flaws like "sanitization loopholes (corner cases)" are structured within the descriptive text details of the corresponding Root Cause node.

Causal Entities (Nodes). To capture the causal structural nature of security flaws, VCKG defines five specialized nodes. These entities represent the essential components of a vulnerability's lifecycle:

- **Entrypoint (EP):** The initial execution context or interface where untrusted input enters the system.
- **Precondition (PC):** The specific environmental states or program conditions required for a flaw to be reachable or triggered.
- **Root Cause (RC):** The core logical error or architectural weakness that inherently constitutes the security flaw.
- **Fix Intent (FI):** The developer's underlying logic and the targeted patch logic applied to neutralize the flaw, serving as the primary differentiator between vulnerable and safe code.
- **CWE:** A standardized abstraction that provides high-level semantic categorization for the specific weakness.

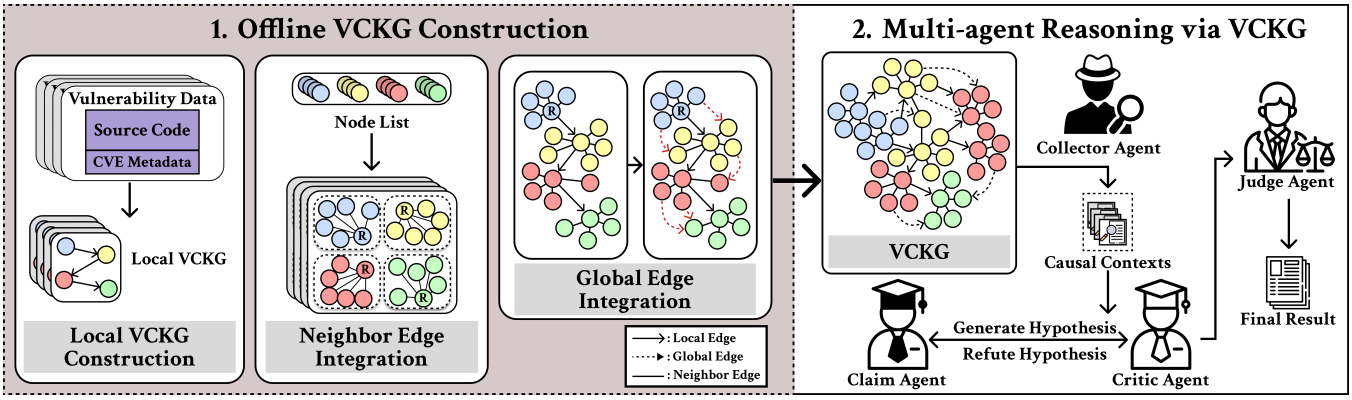

Figure 1: An Overview of the CLEAR Framework

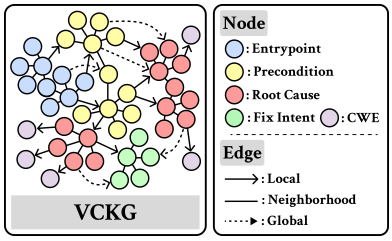

Figure 2: Design of Vulnerability Causal Knowledge Graph

Causal Relations (Edges) The interactions between these entities are defined by three distinct edge types, which categorize the nature of the causal and semantic links:

- **Local Edge:** Represents the internal causal flow within a single vulnerability instance (e.g., within the same function or CVE case). It connects $EP \rightarrow PC \rightarrow RC \rightarrow FI$ and CWE to map the direct propagation path and its corresponding remedy.
- **Neighborhood Edge:** Connects causal entities based on shared semantic properties or logical proximity (excluding CWE). This edge facilitates the discovery of cross-component associations that are not captured by direct execution flows.
- **Global Edge:** Establishes relationships between different Local VCKG instances. It links similar entities across the knowledge base, allowing the model to leverage external causal patterns and previous fix strategies for the current analysis.

The design of VCKG is centered on the insight that vulnerabilities are context-dependent causal events. By explicitly modeling the Fix Intent (FI) and its local causal relationship with the Root Cause (RC), VCKG provides the LLM with the logical "reason" why a patch works. This prevents the model from misidentifying a patched version as vulnerable simply because it shares a high percentage of code tokens with the original version. Furthermore, the categorization of edges into Local, Global, and Neighborhood ensures a balance between deep internal analysis and broad contextual reasoning, making the detection process logically rigorous rather than merely statistical.

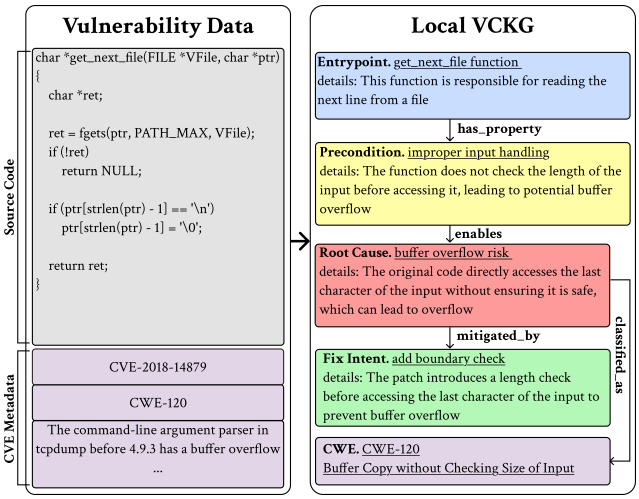

Figure 3: Local Vulnerability Causal Knowledge Graph Example

2.1 Offline Vulnerability Causal Knowledge Graph Construction

The construction of the VCKG is performed in an offline environment to ensure a robust and comprehensive knowledge base before the reasoning process begins. This phase transforms raw vulnerability data—consisting of source code, CVE descriptions, and patch information—into a structured causal network. The construction process is divided into three sequential stages: (1) Local VCKG Construction, (2) Neighbor Edge Integration, and (3) Global Edge Integration. To prevent data leakage and guarantee evaluation integrity, the VCKG is constructed solely from the training split; test code slices are treated strictly as unseen queries and are completely excluded from the graph construction phase.

Local VCKG Construction. The first stage focuses on extracting individual causal chains from specific vulnerability instances, where each Local VCKG corresponds to a single vulnerability instance represented by a function-level code snippet aligned with its associated CVE metadata and patch information. In this setting, one

Local VCKG is constructed per vulnerability-containing function-level code snippet, ensuring that each snippet contributes exactly one isolated causal chain representation. Using this vulnerability data as input, a Large Language Model (LLM) analyzes the logical dependencies within the source code and descriptive metadata to identify the five core causal entities (EP, PC, RC, FI, and CWE) and determine their roles within the vulnerability lifecycle. Due to paper page constraints, the complete prompt templates and system instructions utilized for local VCKG construction are provided in the Supplementary Material.

As illustrated in Figure 3, this stage maps the internal propagation path by establishing Local Edges ($EP \rightarrow PC \rightarrow RC \rightarrow FI$ and CWE), resulting in a set of independent "Local VCKG" units. Each unit represents the isolated causal logic of a single security flaw, providing a granular foundation for the subsequent integration phases.

Neighborhood Edge Integration. While individual Local VCKGs capture the internal causal context of specific vulnerabilities, establishing inter-graph connectivity is essential for constructing a robust and high-performing knowledge base. Neighborhood Edge Integration is the process of linking semantically related causal nodes (EP, PC, RC, FI) across different Local VCKGs to form a cohesive network. To preserve causal-role consistency during graph expansion, Neighborhood Edges are constructed only between nodes of the same causal type. Restricting alignment to same-type nodes prevents structurally incompatible cross-role associations and improves the precision and stability of node-wise causal-context retrieval in the subsequent multi-agent reasoning process. However, performing a pairwise semantic similarity comparison across all nodes in the entire knowledge base is computationally expensive and impractical for large-scale datasets. To ensure both efficiency and precision, we implement two strategic constraints:

- **CWE-based Clustering:** We first organize Local VCKGs into clusters based on their associated CWE Map as defined by the MITRE framework. Semantic similarity comparisons are then restricted to causal nodes within the same CWE cluster, significantly reducing the search space while ensuring that only logically related vulnerabilities are compared.
- **Embedding-based Top-k Filtering:** Within each cluster, we compute semantic embeddings for the nodes and establish Neighbor Edges only for the Top-k most similar counterparts. The value of $k = 5$ was selected to maintain a compact causal neighborhood while preventing excessive context growth that may otherwise introduce redundant information and reduce the effectiveness of downstream LLM-based reasoning.

Through this integration, semantically similar nodes are interconnected into a “neighborhood“ structure. This allows the framework to retrieve not only the target causal chain but also its most relevant neighbors, providing the reasoning agents with a broader spectrum of similar attack patterns and fix strategies during the subsequent detection phase.

Global Edge Integration. The final stage of VCKG construction is Global Edge Integration, a process driven by an LLM to establish causal links between nodes in different Local VCKGs. While Local Edges map the internal causal chains within a single vulnerability data, Global Edges extend these same causal dependencies across

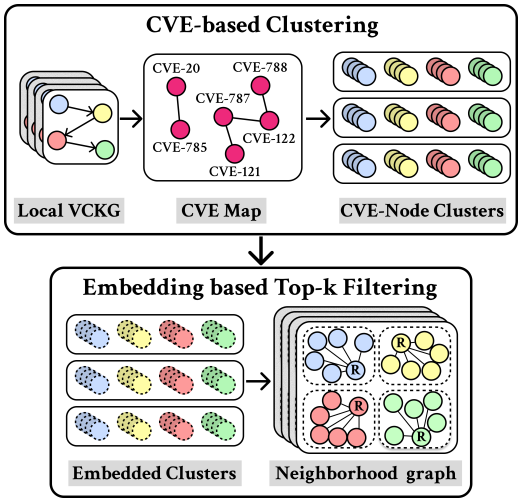

Figure 4: Neighborhood Edge Integration

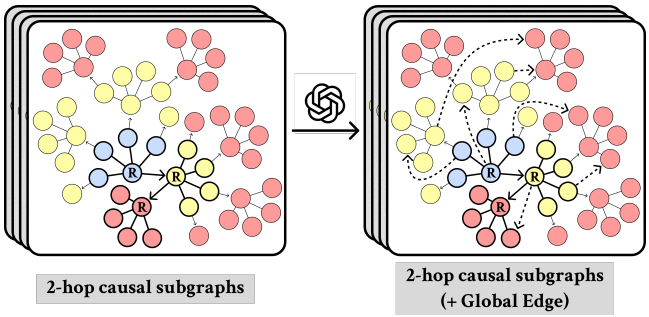

Figure 5: Global Edge Integration

the entire knowledge base by linking entities from disparate Local VCKG units that exhibit functional or logical inter-dependencies.

To ensure computational feasibility and manage the LLM's context window efficiency, we perform this integration by querying the LLM with 2-hop causal subgraphs as the fundamental unit of input. Rather than processing the entire global network at once, the system extracts localized 2-hop paths—such as $Entrypoint \rightarrow Precondition \rightarrow Root\ Cause$ or $Precondition \rightarrow Root\ Cause \rightarrow Fix\ Intent$, including their respective semantic neighborhoods. This windowing approach provides a concentrated context of approximately 260 nodes, allowing the LLM to effectively identify latent causal overlaps where an entity in one instance functionally influences a node in another.

Through this process, Vulnerability Data is transformed from a collection of isolated, unstructured text into a structurally well-defined Knowledge Graph that inherently possesses deep causal insights. As illustrated in Figure 5, this 2-hop strategy prevents the exponential expansion of the search space while maintaining a scalable foundation for the subsequent multi-agent reasoning process. By synthesizing these cross-instance links, the VCKG evolves from a set of fragmented cases into a highly interconnected causal network.

2.2 Multi-Agent Reasoning via VCKG

The Multi-Agent Reasoning phase is the core analytical process where a specialized team of agents, including the Collector, Claim, Critic, and Judge, collaborates to identify vulnerabilities by leveraging structured causal insights from the VCKG. As illustrated in Figure 1, this phase is initiated by the Collector Agent, which performs a deep Causal Context Retrieval to provide the reasoning agents with highly relevant historical evidence grounded in the target code's logic.

As illustrated in Figure 6 the workflow begins with the Collector analyzing the target source code to extract Causal Nodes, with a specific focus on Entrypoints (EP), using the same LLM-driven reasoning mechanism described in the construction phase. Once the local EP nodes are identified, the Collector interacts with the global VCKG to perform a semantic similarity comparison, retrieving the Top-5 most similar historical EP nodes. These retrieved nodes serve as anchors to traverse all associated Local, Neighbor, and Global edges, gathering a comprehensive set of next-hop causal entities.

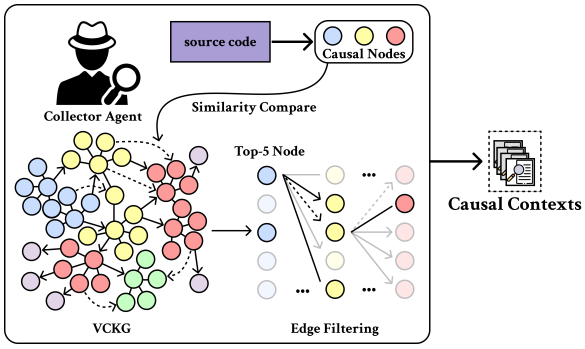

Figure 6: Causal Context Retrieval

To ensure the precision of the reasoning process, the Collector employs an LLM-driven Edge Filtering strategy. Instead of delivering all retrieved nodes, the Collector queries the LLM to evaluate whether each next-hop entity maintains a genuine logical relevance to the specific context of the current source code. Any node deemed irrelevant through this query-based judgement is filtered out.

If this filtering process results in all candidate nodes being removed, the Collector executes a secondary retrieval phase as a fallback mechanism. In this stage, the system re-initiates the similarity comparison using other extracted causal nodes, specifically Precondition (PC) and Root Cause (RC), to identify their respective Top-5 most similar historical counterparts within the VCKG. This iterative expansion ensures that the subsequent agents are provided with validated Causal Contexts even when the initial entrypoint-based search is overly restrictive.

Following this robust retrieval process, the Claim Agent utilizes the validated Causal Contexts as logical anchors to generate a specific vulnerability hypothesis. Unlike conventional prompting that relies on the LLM's internal parameters, the Claim Agent is constrained to map the target code's execution flow onto the retrieved causal paths (e.g., $EP \rightarrow PC \rightarrow RC$), ensuring the hypothesis is grounded in verifiable historical patterns.

To mitigate potential hallucinations or overconfidence, the Critic Agent then performs an adversarial verification. It attempts to refute the proposed hypothesis by identifying logical inconsistencies between the target code's program state and the retrieved causal preconditions, specifically searching for missing fix intents (FI) or unmet preconditions that would invalidate the exploit.

Finally, the Judge Agent reviews the arguments from both sides along with the supporting causal context to reach a final decision. By weighing the Critic's objections against the Claim's evidence, the Judge determines whether a vulnerability truly exists, identifies its specific type (CWE), and explains the underlying cause. This collaborative process ensures that the final result is not just a statistical guess but a conclusion backed by a clear and verifiable reasoning chain.

3 Experimental Setup

This section describes the experimental configuration used to evaluate the effectiveness of CLEAR, including the implementation environment, datasets, evaluation metrics, and baseline methods.

3.1 Implementation Details

All implementations were conducted in `Python 3.12`. We used `LangChain` [4] to construct the multi-agent reasoning pipeline. To ensure fair comparisons across all experimental settings, including baselines and ablation variants, all experiments were performed using the same backbone model, `gpt-4o-mini`, with `temperature=0.0`. For embedding-based retrieval and knowledge graph construction, we used `all-MiniLM-L6-v2`, a Sentence-BERT–based embedding model [28]. The same embedding model was consistently applied to the Collector Agent, vulnerability causal knowledge graph construction, and RAG-based baseline comparisons to maintain experimental consistency.

3.2 Datasets

For the C/C++ setting, we evaluated our approach on the PrimeVul dataset [5], which contains 7,578 training samples, 960 validation samples, and 870 test samples. Following the official pairwise evaluation protocol of PrimeVul, vulnerability detection was evaluated using 433 vulnerable/non-vulnerable pairs constructed from the test split (435 vulnerable and 435 non-vulnerable samples). For CWE classification, evaluation was performed on the vulnerable subset of the test split, consisting of 435 vulnerable samples.

For the Java setting, we constructed a curated Java-Pair dataset by integrating CVEFixes [2], MegaVul [24], and CleanVul [20]. Since CleanVul does not provide CVE or CWE identifiers, we enriched vulnerability metadata by matching commit identifiers using the NVD API [22] and OSV API [10]. To focus on subtle logic-level vulnerability differences, vulnerable/non-vulnerable pairs were filtered using string similarity ≥ 0.8, resulting in 214 training samples, 27 validation samples, and 132 test samples. Vulnerability detection was evaluated using 66 vulnerable/non-vulnerable pairs constructed from the test split, while CWE classification was evaluated on the 66 vulnerable samples. Given the relatively small sample size of the Java-Pair dataset, a single evaluation run could be highly susceptible to statistical volatility. To mitigate this and ensure reliable

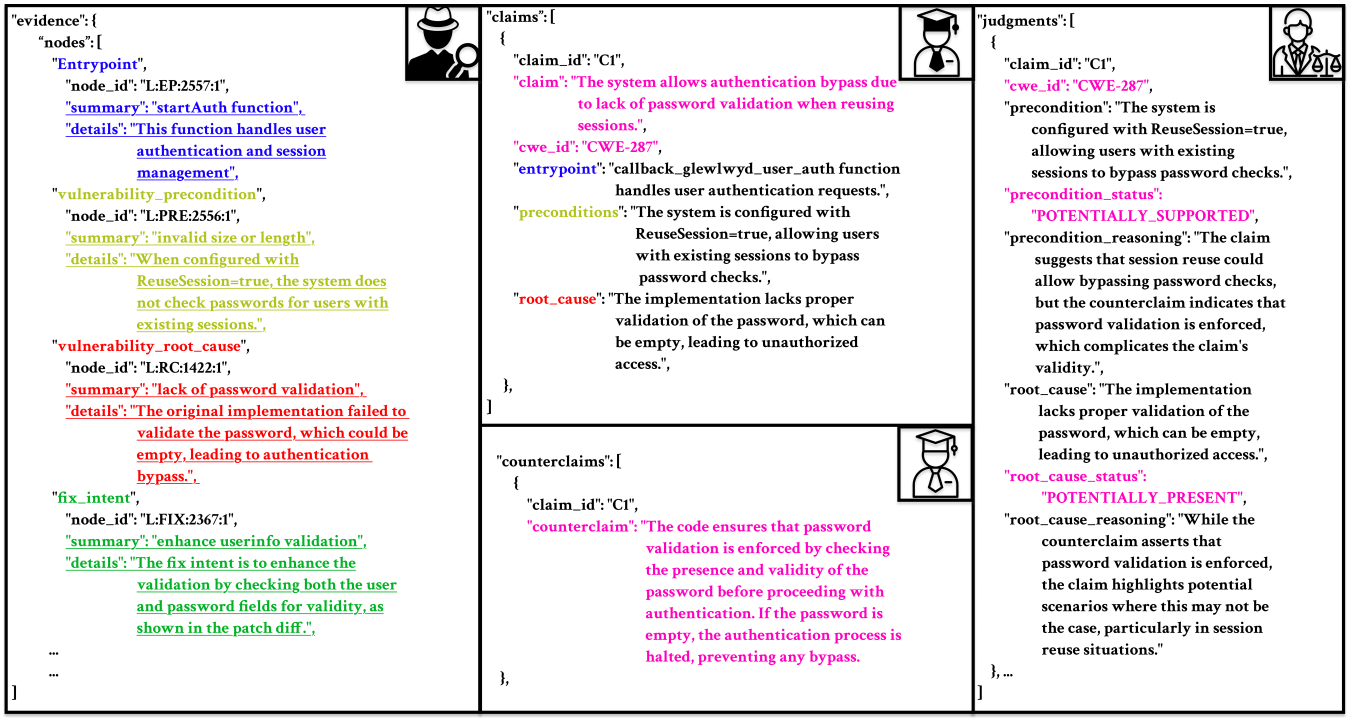

Figure 7: Multi-Agent Reasoning Example

generalization, we repeated the evaluation 10 times over independent iterations and reported the metrics with their corresponding confidence intervals.

3.3 Evaluation Metrics

Following the pairwise evaluation perspective of PrimeVul [5], we report separate metrics for vulnerability detection and CWE classification.

Detection Metrics. We use pairwise metrics to reflect whether the model correctly distinguishes between vulnerable and non-vulnerable code pairs. Pairwise Correct Prediction (P-C) measures fully correct pair decisions, while P-V and P-B capture degenerate behaviors where both snippets are predicted as vulnerable or non-vulnerable, respectively. Pairwise Reversed Prediction (P-R) penalizes failure cases in which the vulnerable/non-vulnerable roles are flipped. We additionally report Vulnerability Pair Score (VPS), which summarizes useful discrimination by rewarding correct pair ordering and discounting reversed predictions. All pairwise metrics are reported as percentages (%).

Classification Metrics. For CWE classification, class imbalance is substantial, and performance must be assessed from multiple angles. Macro-F1 treats all CWE classes equally and highlights robustness on minority classes. Weighted-F1 reflects overall practical performance by accounting for class support. Matthews Correlation Coefficient (MCC) is included as a balanced correlation-based metric that remains informative under skewed label distributions and complements F1-based analysis. For consistency with the detection metrics, all reported values are expressed as percentages (%).

3.4 Baseline Methods

We compare three groups of baselines: Deep learning methods, single-agent methods, and multi-agent methods,. For all baselines, we follow each paper's replication package and preserve the original prompts and evaluation logic for fair comparison. To ensure a controlled evaluation setting, all methods are executed using the same backbone LLM (`gpt-4o-mini`).

Deep learning baselines. For deep learning-based baselines, we evaluate CodeBERT [8] and UniXcoder [12] to assess capabilities of deep learning models. First, we adopt CodeBERT, a bimodal pre-trained Transformer optimized via masked language modeling and replaced token detection to capture NL-PL semantic connections [8]. We fine-tune CodeBERT on our dataset and leverage the pooled `[CLS]` token representations for pairwise discrimination. Second, we integrate UniXcoder, a unified cross-modal model that controls context access via mask attention matrices with prefix adapters, while capturing syntax and structure through bimodal sequences of mapped ASTs and code comments [12]. We fine-tune UniXcoder's encoder and utilize the cosine similarity of the final-layer pooled hidden states to determine vulnerability status. Both models are implemented following their official configurations with identical input lengths and training schedules to ensure a fair comparison.

Single-Agent baselines. For single-agent baselines, we evaluate both prompting-based and Retrieval Augmented Generation based LLM approaches. For prompting-based evaluation, we adopt a Chain-of-Thought (CoT) [5] reasoning strategy where the model directly generates a predicted CWE label step-by-step from the raw input without external structured evidence, evaluating only

vulnerable samples following standard classification protocols. To assess single-agent RAG capabilities, we integrate Vul-RAG [6], a knowledge-level framework that distills high-level, generalizable vulnerability knowledge—encompassing functional semantics, root causes, and fixing solutions—from historical CVE instances. During online inference, Vul-RAG extracts semantics from the target code to retrieve relevant abstraction profiles and sequentially prompts the LLM to verify whether the target snippet exhibits the same vulnerability cause while lacking the corresponding defensive solution.

Multi-Agent baselines. For multi-agent baselines, we include GPTLens [14] and VulTrial [38], which represent collaborative reasoning frameworks for vulnerability analysis. GPTLens performs iterative cross-agent discussion to refine vulnerability judgments through perspective diversification, while VulTrial adopts a courtroom-style debate mechanism that alternates between claim generation and counterargument verification. In our experiments, both frameworks are implemented following the configurations provided in their official replication packages. We preserve their original agent interaction protocols and prompting strategies.

For the CWE classification task, we further follow their classification output processing pipelines to obtain a single predicted CWE label per vulnerable instance. Specifically, GPTLens produces ranked CWE candidates with confidence scores, from which we select the final prediction based on the highest ranking score according to its original evaluation procedure. Similarly, VulTrial generates candidate CWE lists through multi-agent debate outputs recorded in its classification results, which we normalize into single-label predictions by selecting the ground-truth CWE when present among the candidates, and otherwise choosing the top-ranked candidate following its replication setup.

4 Evaluation

Research Question In this section, we evaluate the effectiveness of CLEAR through a series of experiments designed to answer the following research questions.

- **RQ1:** Does CLEAR improve vulnerability detection performance compared to existing SOTA approaches?
- **RQ2:** How does multi-agent contribute to CLEAR's performance compared to conventional retrieval-based approaches?
- **RQ3:** Which components of CLEAR contribute most to the performance improvement?
- **RQ4:** How does CLEAR perform across different LLM backbones?
- **RQ5:** How effectively can CLEAR classify vulnerability types?
- **RQ6:** Does CLEAR construct a high-quality and reliable causal knowledge graph?

RQ1. Does CLEAR improve vulnerability detection performance compared to existing SOTA approaches? This question evaluates whether the proposed framework can more accurately distinguish vulnerable code from patched or benign code. We compare CLEAR with deep learning-based models, single-agent prompting approaches, and recent multi-agent frameworks. Table 1 summarizes the pairwise vulnerability detection results on the PrimeVul and Java-Pair datasets. Overall, CLEAR consistently achieves the highest pairwise discrimination performance across both datasets. On the PrimeVul dataset, CLEAR attains the best performance (P-C = 19.17, VPS = 10.62), outperforming the previous multi-agent baseline VulTrial (P-C = 8.31, VPS = 1.15). This corresponds to a relative improvement of approximately 130.7% in P-C. Similarly, on the Java-Pair dataset, CLEAR achieves (P-C = 21.36 ± 1.48, VPS = 10.15 ± 3.06), improving over VulTrial (P-C = 12.45 ± 2.08, VPS = 4.29 ± 3.29) by approximately 71.56% in P-C.

A consistent pattern emerges when comparing different categories of methods. Deep learning-based models such as CodeBERT and UniXCoder exhibit low P-C scores and high P-V values on both datasets, indicating a tendency to over-predict vulnerabilities without effectively distinguishing vulnerable and patched code pairs. The single-agent CoT approach provides moderate improvements compared to encoder-based models but still produces unstable pairwise discrimination results, as reflected in its relatively low VPS scores across both datasets. Among multi-agent baselines, GPTLens shows particularly low P-C performance (0.46 on PrimeVul and 0.00 on Java-Pair), suggesting difficulty in distinguishing vulnerability pairs under the pairwise evaluation setting. VulTrial improves over earlier baselines but still remains limited in capturing subtle vulnerability differences, especially on logic-level vulnerability pairs in the Java-Pair dataset. In contrast, CLEAR significantly increases pairwise discrimination accuracy while substantially reducing excessive vulnerability predictions compared to other multi-agent methods. These results suggest that incorporating structured causal reasoning improves the reliability of vulnerability detection, particularly when distinguishing vulnerable code from closely related patched or benign variants.

Answer to RQ1. CLEAR achieves the best pairwise vulnerability detection performance across both datasets, improving P-C by 130.7% on PrimeVul and 71.56% on Java-Pair compared to the previous multi-agent SOTA method. These results demonstrate that causal-chain–guided evidence retrieval enables more reliable discrimination between vulnerable and patched code than existing approaches.

RQ2: How does multi-agent contribute to CLEAR's performance compared to conventional retrieval-based approaches?

To evaluate the architectural contribution of CLEAR's multi-agent coordination, we conduct an ablation study comparing our full framework with two single-agent RAG baselines that retrieve context from the VCKG under different granularities. The first baseline, *Instance-level retrieval*, bypasses multi-agent cooperative verification by employing a single agent to retrieve the most similar Local VCKG subgraph based on overall embedding similarity. The second baseline, *Chunk-level retrieval*, similarly uses a single agent to retrieve semantically similar causal nodes independently for each causal type without considering structural linkages. Table 2 presents the comparison results of this ablation study.

Overall, the full multi-agent configuration of CLEAR outperforms both single-agent retrieval-based ablation variants across both datasets. On the PrimeVul dataset, the single-agent instance-level variant struggles significantly, achieving (P-C = 4.62, VPS = -0.23), which underlines the unreliability of naive similarity-based

Table 1: Pairwise vulnerability detection results across PrimeVul and Java-Pair dataset. Higher is better for P-C and VPS; lower is better for P-V, P-B, and P-R.

Agents	Method	P-C (↑)	P-V (↓)	P-B (↓)	P-R (↓)	VPS (↑)	Dataset
DL	CodeBERT	3.00	54.96	39.72	2.30	0.69	PrimeVul
DL	UniXCoder	6.23	64.66	28.40	**0.69**	5.54	PrimeVul
Single-Agent	CoT	6.47	67.90	18.94	6.70	-0.23	PrimeVul
Single-Agent	Vul-RAG	8.78	42.26	38.57	10.39	-1.62	PrimeVul
Multi-Agent	GPTLens	0.46	95.84	**2.08**	1.62	-1.15	PrimeVul
Multi-Agent	VulTrial	8.31	76.67	7.85	7.16	1.15	PrimeVul
Multi-Agent	**Ours**	**19.17**	**4.62**	67.67	8.55	**10.62**	PrimeVul
DL	CodeBERT	0.30 ± 0.68	7.87 ± 11.97	91.36 ± 13.22	**0.45 ± 0.73**	−0.16 ± 0.34	Java-Pair
DL	UniXCoder	0.00 ± 0.00	43.93 ± 0.00	50.00 ± 0.00	6.06 ± 0.00	−6.07 ± 0.00	Java-Pair
Single-Agent	CoT	5.15 ± 1.16	81.06 ± 1.17	9.69 ± 1.27	4.09 ± 0.89	1.06 ± 1.53	Java-Pair
Single-Agent	Vul-RAG	16.06 ± 3.03	51.36 ± 2.07	21.51 ± 2.69	11.06 ± 1.77	5.00 ± 3.92	Java-Pair
Multi-Agent	GPTLens	0.45 ± 0.52	95.30 ± 0.79	**3.18 ± 0.34**	1.06 ± 0.73±	−0.61 ± 1.04	Java-Pair
Multi-Agent	VulTrial	12.45 ± 2.08	67.69 ± 3.06	11.69 ± 1.06	8.16 ± 2.20	4.29 ± 3.29	Java-Pair
Multi-Agent	Ours	**21.36 ± 1.48**	**9.69 ± 2.05**	57.72 ± 3.77	11.21 ± 2.98	**10.15 ± 3.06**	Java-Pair

Table 2: Comparison of retrieval strategies for pairwise vulnerability detection on PrimeVul and Java-Pair datasets. Higher values are better for P-C and VPS, while lower values are better for P-V, P-B, and P-R.

Method	P-C (↑)	P-V (↓)	P-B (↓)	P-R (↓)	VPS (↑)	Dataset
Instance-level	4.62	84.99	5.54	4.85	-0.23	PrimeVul
Chunk-level	6.00	87.30	**3.00**	**3.70**	2.31	PrimeVul
Ours	**19.17**	**4.62**	67.67	8.55	**10.62**	PrimeVul
Instance-level	1.67 ± 0.48	19.24 ± 21.46	76.82 ± 24.34	2.27 ± 2.60	−0.61 ± 2.17	Java-Pair
Chunk-level	4.39 ± 2.08	21.21 ± 19.17	73.18 ± 22.08	**1.21 ± 1.56**	3.18 ± 1.12	Java-Pair
Ours	**21.36 ± 1.48**	**9.69 ± 2.05**	**57.72 ± 3.77**	11.21 ± 2.98	**10.15 ± 3.06**	Java-Pair

instance retrieval for pairwise discrimination. While retrieving isolated nodes independently via the chunk-level variant modestly improves performance (P-C = 6.00, VPS = 2.31), it remains highly insufficient as the single agent fails to capture the logical connections between disparate semantic fragments. In contrast, by enabling cooperative reasoning among specialized agents over the causal chain, CLEAR achieves (P-C = 19.17, VPS = 10.62).

We observe a highly consistent trend on the Java-Pair dataset. The single-agent instance-level baseline performs (P-C = 1.67 ± 0.48, VPS = −0.61 ± 2.17), while the chunk-level baseline yields only modest improvements (P-C = 4.39 ± 2.08, VPS = 3.18 ± 1.12). CLEAR boosts performance to a P-C score of 21.36 ± 1.48 and a VPS of 10.15 ± 3.06. These improvements can be directly attributed to CLEAR's structured multi-agent coordination. CLEAR's multi-agent pipeline progressively expands and cross-verifies evidence along logical causal dependencies. This structured collaboration enables the reasoning agents to collectively verify whether complex vulnerability conditions are fully satisfied, demonstrating that multi-agent causal-chain guidance is essential to achieving reliable pairwise vulnerability discrimination.

Answer to RQ2. Our ablation study demonstrates that CLEAR's multi-agent causal-chain coordination is crucial for performance. It outperforms conventional single-agent instance-level and chunk-level retrieval baselines, proving that multi-agent collaborative reasoning over structured causal dependencies is more effective than individual embedding-based retrieval.

RQ3: Which causal evidence components contribute most to the final prediction?

In this question, we investigate the contribution of each causal component in CLEAR by removing individual nodes. Table 3 presents the ablation results under different node-removal settings. Overall, completely removing the causal knowledge graph (*No VCKG (Agent Only)*) leads to the most severe performance degradation, with P-C dropping to 8.08 on PrimeVul and 14.39 ± 3.58 on Java-Pair. Among the individual components, removing the *Entrypoint* node yields the least performance degradation, with P-C scores remaining relatively high at 18.24 on PrimeVul and 19.69 ± 4.65 on Java-Pair. This suggests that while execution context is useful, the reasoning agents can largely infer execution entry points from the source code itself.

In contrast, excluding the core vulnerability semantics—namely the *Precondition*, *Root Cause*, or *Fix Intent* nodes—leads to the most pronounced performance declines, demonstrating that explicit causal representations of the underlying triggers, flaws, and corresponding fix designs serve as the primary pillars for reliable pairwise discrimination. Specifically, removing the *Precondition* node markedly degrades performance, with P-C dropping to 16.17 on PrimeVul and 19.54 ± 1.87 on Java-Pair (VPS drops severely to 0.90 ± 3.47). Similarly, without the *Root Cause* node, P-C drops to 13.63 on PrimeVul and 17.12 ± 2.84 on Java-Pair, while removing

Table 3: Ablation results on pairwise vulnerability detection for PrimeVul and Java-Pair dataset. Higher values indicate better performance for P-C and VPS, while lower values are preferred for P-V, P-B, and P-R.

Method	P-C (↑)	P-V (↓)	P-B (↓)	P-R (↓)	VPS (↑)	Dataset
No VCKG (Agent Only)	8.08	28.87	**22.86**	40.18	-32.10	PrimeVul
No Entrypoint	18.24	**3.23**	67.21	11.32	6.93	PrimeVul
No Precondition	16.17	8.08	62.36	13.39	2.77	PrimeVul
No Root Cause	13.63	9.01	66.97	10.39	3.23	PrimeVul
No Fix Intent	14.32	3.46	70.67	11.55	2.77	PrimeVul
Full	**19.17**	4.62	67.67	**8.55**	**10.62**	PrimeVul
No VCKG (Agent Only)	14.39 ± 3.58	62.27 ± 3.59	**9.84 ± 1.92**	13.48 ± 1.48	0.90 ± 3.76	Java-Pair
No Entrypoint	19.69 ± 4.65	18.48 ± 2.97	51.36 ± 4.52	**10.45 ± 4.10**	9.24 ± 8.03	Java-Pair
No Precondition	19.54 ± 1.87	17.42 ± 2.40	44.39 ± 3.27	18.63 ± 2.60	0.90 ± 3.47	Java-Pair
No Root Cause	17.12 ± 2.84	15.90 ± 3.65	50.45 ± 3.39	16.51 ± 3.04	0.60 ± 3.61	Java-Pair
No Fix Intent	17.12 ± 2.89	11.66 ± 2.28	56.96 ± 3.93	14.24 ± 2.71	2.87 ± 4.16	Java-Pair
Full	**21.36 ± 1.48**	**9.69 ± 2.05**	57.72 ± 3.77	11.21 ± 2.98	**10.15 ± 3.06**	Java-Pair

the *Fix Intent* node further reduces P-C to 14.32 on PrimeVul and 17.12 ± 2.89 on Java-Pair.

Answer to RQ3. While all causal nodes contribute to CLEAR, the Precondition, Root Cause, and Fix Intent nodes play the most critical roles. Removing the execution context (Entrypoint) has a marginal impact, whereas excluding core trigger conditions and patch semantics leads to severe performance degradation.

RQ4: How does CLEAR perform across different LLM backbones?

To evaluate the generalization and stability of our framework across different foundation models, we analyzed the performance of CLEAR using various state-of-the-art LLM backbones. Table 4 presents the empirical results on the PrimeVul and Java-Pair datasets.

Larger and more advanced reasoning models demonstrate a superior capacity to grasp complex patching logic and align causal states. On the PrimeVul dataset, gpt-5-mini achieves the highest performance with P-C score of 27.48 and VPS of 19.63. In contrast, smaller backbones like gemini-2.5-flash perform worse, yielding a P-C score of 19.40 and a negative VPS of -3.00, which indicates a struggle to reliably reason through patch boundaries.

We observe a distinct trade-off between conservative classification (preventing false positives) and sensitive detection across different backbones. Specifically, gpt-4o-mini exhibits a highly conservative decision profile; on the PrimeVul dataset, it records the lowest rate of incorrect vulnerability predictions (P-V = 4.62), yet it suffers from a disproportionately high rate of overpredicting code-patch pairs as benign (P-B = 67.67). Conversely, gemini-2.5-flash makes more aggressive claims, yielding a higher P-V rate (35.57) but maintaining a much lower benign bias (P-B = 22.63).

The empirical results on the Java-Pair dataset, validate the robustness and consistency of CLEAR under noisy conditions. Even when utilizing lighter backbones, CLEAR maintains stable performance with narrow variances. Notably, gpt-4o-mini achieves a robust P-C score of 21.36 ± 1.48 and a VPS of 10.15 ± 3.06, which closely matches the performance of the larger gpt-5-mini (21.66 ± 3.54 P-C, 10.75 ± 4.25 VPS) while exhibiting a much tighter variance.

While gpt-5-mini yields the highest absolute scores on PrimeVul, we adopt gpt-4o-mini as our primary backbone for the main evaluations. This design choice is driven by two key factors: (1) Cost-Effectiveness and Practicality: In real-world static analysis pipelines, utilizing highly resource-intensive reasoning models like gpt-5-mini introduces prohibitive API costs and latency at scale, whereas gpt-4o-mini offers a highly practical balance of low cost and rapid inference. (2) Statistical Stability: As demonstrated on the Java-Pair dataset, gpt-4o-mini achieves significantly tighter confidence intervals compared to gpt-5-mini. This statistical tightness proves that CLEAR's multi-agent coordination can effectively suppress reasoning variance on a highly accessible, lightweight model. This choice establishes a more rigorous baseline, showing that CLEAR does not rely on brute-force model scale to achieve robust and reliable vulnerability discrimination.

Answer to RQ4. CLEAR exhibits robust and consistent performance across diverse LLM backbones. While advanced models like gpt-5-mini maximize raw alignment precision, we establish gpt-4o-mini as our primary backbone due to its superior cost-efficiency and significantly narrower prediction variance, proving that CLEAR delivers highly stable and practical vulnerability analysis without relying on excessive model scale.

RQ5: How effectively can CLEAR classify vulnerability types?

This question evaluates the ability of CLEAR to classify vulnerabilities into their corresponding CWE categories. Table 5 summarizes the classification results on the PrimeVul and Java-Pair datasets. Overall, CLEAR consistently achieves the best performance across all evaluation metrics, outperforming both single-agent and multi-agent baselines on both datasets. On the PrimeVul dataset, CLEAR achieves a Macro-F1 score of 8.43, improving over the previous multi-agent baseline VulTrial (Macro-F1 = 6.78) by approximately 24.3%. CLEAR also achieves the highest Weighted-F1 (23.57) and MCC (19.84), indicating improved classification reliability under class-imbalanced conditions. On the Java-Pair dataset, CLEAR attains a Macro-F1 score of 24.51, improving over VulTrial (Macro-F1 = 16.22) by approximately 51.1%. CLEAR further

Table 4: Results of CLEAR with different LLM backbones. Higher is better for P-C and VPS; lower is better for P-V, P-B, and P-R.

Model	P-C (↑)	P-V (↓)	P-B (↓)	P-R (↓)	VPS (↑)	Dataset
gemini-2.5-flash	19.40	35.57	**22.63**	22.40	−3.00	PrimeVul
gemini-3.1-flash-lite	21.48	32.10	33.03	13.39	8.08	PrimeVul
gpt-4.1-nano	21.25	18.24	42.03	18.48	2.77	PrimeVul
gpt-4o-mini	19.17	4.62	67.67	8.55	10.62	PrimeVul
gpt-5-mini	**27.48**	**3.23**	61.43	**7.85**	**19.63**	PrimeVul
gemini-2.5-flash	**24.42 ± 3.15**	39.16 ± 3.01	19.05 ± 2.76	17.35 ± 2.48	7.07 ± 4.44	Java-Pair
gemini-3.1-flash-lite	18.48 ± 1.67	50.60 ± 0.91	**15.15 ± 1.14**	15.75 ± 1.37	2.72 ± 2.97	Java-Pair
gpt-4.1-nano	19.69 ± 3.19	14.39 ± 2.05	43.93 ± 3.27	21.96 ± 4.43	−2.28 ± 6.91	Java-Pair
gpt-4o-mini	21.36 ± 1.48	**9.69 ± 2.05**	57.72 ± 3.77	11.21 ± 2.98	10.15 ± 3.06	Java-Pair
gpt-5-mini	21.66 ± 3.54	17.12 ± 2.60	50.30 ± 4.84	**10.90 ± 2.49**	**10.75 ± 4.25**	Java-Pair

Table 5: CWE classification results on PrimeVul and Java-Pair datasets. Higher is better for Macro-F1, Weighted-F1, and MCC.

Agents	Method	Macro-F1 (↑)	Weighted-F1 (↑)	MCC (↑)	Dataset
Single-Agent	CoT	3.14	10.95	6.36	PrimeVul
Multi-Agent	GPTLens	5.41	21.50	17.81	PrimeVul
Multi-Agent	VulTrial	6.78	15.36	13.14	PrimeVul
Multi-Agent	**Ours**	**8.43**	**23.57**	**19.84**	PrimeVul
Single-Agent	CoT	8.13	20.08	19.98	Java-Pair
Multi-Agent	GPTLens	8.41	20.61	18.62	Java-Pair
Multi-Agent	VulTrial	16.22	32.93	31.84	Java-Pair
Multi-Agent	**Ours**	**24.51**	**38.60**	**40.52**	Java-Pair

achieves the best Weighted-F1 (38.60) and MCC (40.52), demonstrating stronger discrimination capability across semantically similar vulnerability categories. Single-agent approaches and early multi-agent methods exhibit limited classification capability, suggesting difficulty in capturing fine-grained vulnerability semantics.

Notably, while early multi-agent frameworks like GPTLens show reasonable performance on PrimeVul, they suffer from severe degradation on the more structurally complex Java-Pair dataset, even underperforming the single-agent CoT baseline in terms of MCC (18.62 vs. 19.98). In contrast, CLEAR maintains a steep and consistent performance ascent across both datasets, validating that our structured causal knowledge alignment is highly robust against the escalating semantic complexity of object-oriented codebase taxonomies.

Answer to RQ5. CLEAR achieves the best CWE classification performance across both datasets, improving Macro-F1 by 24.3% on PrimeVul and 51.1% on Java-Pair compared to the previous multi-agent SOTA method. These results demonstrate that grounding predictions in structured causal evidence enables more accurate classification across diverse vulnerability types.

RQ6. Does CLEAR construct a high-quality and reliable causal knowledge graph?

To address RQ6, we evaluate whether CLEAR constructs a high-quality and reliable causal knowledge graph by conducting a human-centric qualitative study. We sampled 30 representative VCKG instances across the top-30 CWE categories and appointed two domain experts, consisting of one Ph.D. researcher and one Master's researcher specializing in software security, to perform a blind review. The evaluators assessed the structural fidelity and logical soundness of the VCKG by validating each of its three progressive construction stages on a 5-point Likert scale (1: Poor, 5: Excellent). Specifically, the evaluation was conducted by examining each connected triplet as a distinct unit, consisting of two nodes and their intersecting edge, across three criteria:

- **Local VCKG Validity:** Manually inspects whether the extracted node and edge details precisely capture the semantics of the actual source method.
- **Neighbor Edge Validity:** Measures the semantic coherence and proximity between the interconnected local structures.
- **Global Edge Validity:** Checks if the global edges accurately bridge distinct vulnerabilities to facilitate the transfer of causal security knowledge within the graph.

The empirical findings from our human evaluation validate the semantic high-fidelity and architectural robustness of the constructed graphs across all progressive stages. For the first stage, CLEAR achieved a remarkably high score in *Local VCKG Validity* (4.83 ± 0.56) with a quadratic weighted Cohen's Kappa of $\kappa = 0.76$. In the subsequent scaling stages, the graph maintained solid architectural validity, with *Neighbor Edge Validity* scoring 3.58 ± 1.07 ($\kappa = 0.45$) and *Global Edge Validity* scoring 4.14 ± 1.10 ($\kappa = 0.51$). Both stages fall within the *moderate agreement* spectrum, which is justified considering the inherent cognitive complexity and interpretive subjectivity involved in assessing intermediate security linkages.

The noticeable drop in consistency at the neighbor edge layer reflects the evaluation difficulty caused by textually diverse yet

structurally adjacent local contexts. However, the *Global Edge Validity* successfully rebounded to a high mark of 4.14 with an increased consensus of $\kappa = 0.51$. This pivotal trend empirically proves that the multi-agent orchestration within CLEAR effectively filters out localized syntactic noise from neighbor relations, successfully crystallizing shared causal invariants and high-level vulnerability mechanisms that both domain experts found deeply rational.

Answer to RQ6.
CLEAR constructs a reasonably sound causal knowledge graph with acceptable semantic alignment. Based on an internal expert audit conducted by the author team, it exhibits high semantic fidelity at the local node level (4.83/5.0, $\kappa = 0.7578$) and maintains moderate-to-high coherence across global causal invariants (4.14/5.0, $\kappa = 0.5143$), confirming that the structured graph captures valid security knowledge despite remaining local edge noise.

5 Discussion

Edge Case and Failure Mode Analysis To map the logical limits of our multi-agent reasoning loop, we analyze CLEAR's behavior under complex scenarios alongside its primary failure mode of benign-benign (P-B) over-predictions. While automated analysis often struggles with multi-precondition flaws (e.g., Use-After-Free) due to local VCKG abstraction limits that generalize micro-level variables (e.g., $tlen == tcap$) for semantic generality, CLEAR mitigates this through a structured *Collector Agent* that aggregates neighboring edges and global causal invariants to restore discriminative power. Conversely, our deep-dive into P-B over-predictions reveals two systemic bottlenecks: (1) *Cross-Domain Context Pollution*, where out-of-domain security knowledge fetched during retrieval prompts the Critic Agent to construct conservative counterclaims, leading to false-positive-preventing rejections by the Judge Agent; and (2) the *Cognitive Illusion of Defensive Constructs*, where the LLM backbone misinterprets superficial error handling (e.g., `NULL` checks) as proactive input validation, prematurely discarding valid vulnerability hypotheses. Due to space constraints, comprehensive code snippets, prompt templates, and agentic trace logs detailing these multi-precondition cases and failure-mode instances (CVE-2019-11929, CVE-2021-37683, and CVE-2019-14464) are provided in the Supplementary Material.

Future Directions While CLEAR successfully leverages high-level causal chains for vulnerability reasoning, we identify two promising avenues to enhance its precision and scalability. First, to track micro-level code properties, future work should couple semantic VCKG nodes with formal program analysis; control-flow conditions can be captured by aligning intra-procedural entities (Entrypoints and Preconditions) with Abstract Syntax Tree (AST) token tracking, while data-flow dependencies can be embedded directly into Root Cause and Fix Intent nodes. Second, scaling CLEAR to repository-level scans represents a critical frontier. Following state-of-the-art inter-procedural semantic completion frameworks like Wu et al. [39], future iterations can synthesize a *Multi-Procedural VCKG* that globally maps control-flow and data-dependencies, enriching local nodes with caller/callee semantic summaries (such as lock boundaries and resource deallocations) and tracking inter-procedural taint flows across library interfaces. Integrating these structural invariants and repository-wide contexts will equip reasoning agents to cross-verify logical hypotheses against concrete program dependencies, ultimately advancing automated, multi-agent vulnerability analysis.

6 Limitations

Although CLEAR achieves significant performance improvements over existing approaches through a causal knowledge graph and a multi-agent verification framework, several limitations remain. These limitations also point to promising directions for future research.

Semantic Similarity Bias The semantic neighbor connections in the knowledge graph are constructed using cosine similarity over semantic-embeddings. While this approach is computationally efficient, semantic similarity does not always guarantee causal consistency. Nodes with similar textual descriptions may be connected even when they are causally unrelated, while nodes describing the same vulnerability mechanism may remain disconnected if their textual representations differ. To mitigate this issue, we introduce an additional LLM-based validation step during the cross-CVE bridging stage. However, the inherent limitations of similarity-based preprocessing still remain. Future research could address this limitation by designing hybrid similarity metrics that incorporate structural information such as AST patterns, data-flow dependencies, or API usage patterns.

7 Conclusion

This work proposes CLEAR, a multi-agent framework that reframes vulnerability detection as a structured causal reasoning task. By modeling vulnerabilities as causal chains within our Vulnerability Causal Knowledge Graph (VCKG) comprising Entrypoints, Preconditions, Root Causes, and Fix Intents, we overcome the inherent limitations of surface-level semantic matching. Our verification-oriented pipeline, which integrates Collector, Claim, Critic, and Judge agents, effectively mitigates reasoning hallucinations by grounding agentic debate in retrieved causal contexts. Empirical evaluations demonstrate that CLEAR significantly outperforms state-of-the-art models. These results validate that the integration of structural causal grounding with agentic collaboration is essential for precise vulnerability analysis, providing a robust and scalable direction for future LLM-driven security research.

Data Availability

The datasets and code generated during the current study are available in the figshare repository, https://doi.org/10.6084/m9.figshare.33016343

References

[1] Zahra Abbasiantaeb, Yifei Yuan, Evangelos Kanoulas, and Mohammad Alian-nejadi. 2024. Let the LLMs Talk: Simulating Human-to-Human Conversational QA via Zero-Shot LLM-to-LLM Interactions. In *Proceedings of the 17th ACM International Conference on Web Search and Data Mining* (Merida, Mexico) *(WSDM '24)*. Association for Computing Machinery, New York, NY, USA, 8–17. doi:10.1145/3616855.3635856

[2] Guru Bhandari, Amara Naseer, and Leon Moonen. 2021. CVEfixes: automated collection of vulnerabilities and their fixes from open-source software. In *Proceedings of the 17th International Conference on Predictive Models and Data Analytics in Software Engineering* (Athens, Greece) *(PROMISE 2021)*. Association for Computing Machinery, New York, NY, USA, 30–39. doi:10.1145/3475960.3475985

[3] Saikat Chakraborty, Rahul Krishna, Yangruibo Ding, and Baishakhi Ray. 2021. Deep learning based vulnerability detection: Are we there yet? *IEEE Transactions on Software Engineering* 48, 9 (2021), 3280–3296.

[4] Harrison Chase. 2022. *LangChain*. https://github.com/langchain-ai/langchain

[5] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We?. In *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering* (Ottawa, Ontario, Canada) *(ICSE '25)*. IEEE Press, 1729–1741. doi:10.1109/ICSE55347.2025.00038

[6] Xueying Du, Geng Zheng, Kaixin Wang, Yi Zou, Yujia Wang, Wentai Deng, Jiayi Feng, Mingwei Liu, Bihuan Chen, Xin Peng, Tao Ma, and Yiling Lou. 2026. Vul-RAG: Enhancing LLM-based Vulnerability Detection via Knowledge-level RAG. *ACM Trans. Softw. Eng. Methodol.* (Feb. 2026). doi:10.1145/3797277 Just Accepted.

[7] Yilun Du, Shuang Li, Antonio Torralba, Joshua B. Tenenbaum, and Igor Mordatch. 2024. Improving factuality and reasoning in language models through multiagent debate. In *Proceedings of the 41st International Conference on Machine Learning* (Vienna, Austria) *(ICML'24)*. JMLR.org, Article 467, 31 pages.

[8] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Findings of the Association for Computational Linguistics: EMNLP 2020*, Trevor Cohn, Yulan He, and Yang Liu (Eds.). Association for Computational Linguistics, Online, 1536–1547. doi:10.18653/v1/2020.findings-emnlp.139

[9] Yunfan Gao, Yun Xiong, Xinyu Gao, Kangxiang Jia, Jinliu Pan, Yuxi Bi, Yi Dai, Jiawei Sun, Meng Wang, and Haofen Wang. 2023. Retrieval-augmented generation for large language models: A survey. *arXiv preprint arXiv:2312.10997* (2023).

[10] Google Open Source Security. 2026. OSV: Open Source Vulnerabilities. https://osv.dev/. Accessed: 2026-02-24.

[11] Katerina Goseva-Popstojanova and Andrei Perhinschi. 2015. On the capability of static code analysis to detect security vulnerabilities. *Inf. Softw. Technol.* 68, C (Dec. 2015), 18–33. doi:10.1016/j.infsof.2015.08.002

[12] Daya Guo, Shuai Lu, Nan Duan, Yanlin Wang, Ming Zhou, and Jian Yin. 2022. UniXcoder: Unified Cross-Modal Pre-training for Code Representation. In *Proceedings of the 60th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Smaranda Muresan, Preslav Nakov, and Aline Villavicencio (Eds.). Association for Computational Linguistics, Dublin, Ireland, 7212–7225. doi:10.18653/v1/2022.acl-long.499

[13] Junda He, Christoph Treude, and David Lo. 2025. LLM-Based Multi-Agent Systems for Software Engineering: Literature Review, Vision, and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* 34, 5, Article 124 (May 2025), 30 pages. doi:10.1145/3712003

[14] Sihao Hu, Tiansheng Huang, Fatih İlhan, Selim Furkan Tekin, and Ling Liu. 2023. Large language model-powered smart contract vulnerability detection: New perspectives. In *2023 5th IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*. IEEE, 297–306. doi:10.1109/TPS-ISA58951.2023.00044

[15] Jie Huang, Xinyun Chen, Swaroop Mishra, Huaixiu Steven Zheng, Adams Wei Yu, Xinying Song, and Denny Zhou. 2023. Large language models cannot self-correct reasoning yet. *arXiv preprint arXiv:2310.01798* (2023).

[16] Lei Huang, Weijiang Yu, Weitao Ma, Weihong Zhong, Zhangyin Feng, Haotian Wang, Qianglong Chen, Weihua Peng, Xiaocheng Feng, Bing Qin, and Ting Liu. 2025. A Survey on Hallucination in Large Language Models: Principles, Taxonomy, Challenges, and Open Questions. *ACM Trans. Inf. Syst.* 43, 2, Article 42 (Jan. 2025), 55 pages. doi:10.1145/3703155

[17] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. 2013. Why don't software developers use static analysis tools to find bugs?. In *2013 35th International Conference on Software Engineering (ICSE)*. IEEE, 672–681.

[18] Arvinder Kaur and Ruchikaa Nayyar. 2020. A Comparative Study of Static Code Analysis tools for Vulnerability Detection in C/C++ and JAVA Source Code. *Procedia Computer Science* 171 (2020), 2023–2029. doi:10.1016/j.procs.2020.04.217 Third International Conference on Computing and Network Communications (CoCoNet'19).

[19] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. 2020. Retrieval-augmented generation for knowledge-intensive NLP tasks. In *Proceedings of the 34th International Conference on Neural Information Processing Systems* (Vancouver, BC, Canada) *(NIPS '20)*. Curran Associates Inc., Red Hook, NY, USA, Article 793, 16 pages.

[20] Yikun Li, Ting Zhang, Ratnadira Widyasari, Yan Naing Tun, Huu Hung Nguyen, Tan Bui, Ivana Clairine Irsan, Yiran Cheng, Xiang Lan, Han Wei Ang, et al. 2024. Cleanvul: Automatic function-level vulnerability detection in code commits using llm heuristics. *arXiv preprint arXiv:2411.17274* (2024).

[21] Tian Liang, Zhiwei He, Wenxiang Jiao, Xing Wang, Yan Wang, Rui Wang, Yujiu Yang, Shuming Shi, and Zhaopeng Tu. 2024. Encouraging Divergent Thinking in Large Language Models through Multi-Agent Debate. In *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing*, Yaser Al-Onaizan, Mohit Bansal, and Yun-Nung Chen (Eds.). Association for Computational Linguistics, Miami, Florida, USA, 17889–17904. doi:10.18653/v1/2024.emnlp-main.992

[22] National Institute of Standards and Technology. 2026. NVD Developers - Vulnerabilities API. https://nvd.nist.gov/developers/vulnerabilities. Accessed: 2026-02-24.

[23] Alexander Tobias Neumann, Yue Yin, Sulayman Sowe, Stefan Decker, and Matthias Jarke. 2025. An LLM-Driven Chatbot in Higher Education for Databases and Information Systems. *IEEE Transactions on Education* 68, 1 (2025), 103–116. doi:10.1109/TE.2024.3467912

[24] Chao Ni, Liyu Shen, Xiaohu Yang, Yan Zhu, and Shaohua Wang. 2024. MegaVul: A C/C++ Vulnerability Dataset with Comprehensive Code Representations. In *Proceedings of the 21st International Conference on Mining Software Repositories* (Lisbon, Portugal) *(MSR '24)*. Association for Computing Machinery, New York, NY, USA, 738–742. doi:10.1145/3643991.3644886

[25] Chao Ni, Xin Yin, Kaiwen Yang, Dehai Zhao, Zhenchang Xing, and Xin Xia. 2023. Distinguishing look-alike innocent and vulnerable code by subtle semantic representation learning and explanation. In *Proceedings of the 31st ACM joint european software engineering conference and symposium on the foundations of software engineering*. 1611–1622.

[26] Oded Ovadia, Menachem Brief, Moshik Mishaeli, and Oren Elisha. 2024. Fine-tuning or retrieval? comparing knowledge injection in llms. In *Proceedings of the 2024 conference on empirical methods in natural language processing*. 237–250.

[27] Md Mahbubur Rahman, Ira Ceka, Chengzhi Mao, Saikat Chakraborty, Baishakhi Ray, and Wei Le. 2024. Towards Causal Deep Learning for Vulnerability Detection. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering* (Lisbon, Portugal) *(ICSE '24)*. Association for Computing Machinery, New York, NY, USA, Article 153, 11 pages. doi:10.1145/3597503.3639170

[28] Nils Reimers and Iryna Gurevych. 2019. Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks. In *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)*, Kentaro Inui, Jing Jiang, Vincent Ng, and Xiaojun Wan (Eds.). Association for Computational Linguistics, Hong Kong, China, 3982–3992. doi:10.18653/v1/D19-1410

[29] Niklas Risse and Marcel Böhme. 2024. Uncovering the limits of machine learning for automatic vulnerability detection. In *Proceedings of the 33rd USENIX Conference on Security Symposium* (Philadelphia, PA, USA) *(SEC '24)*. USENIX Association, USA, Article 238, 18 pages.

[30] Ze Sheng, Zhicheng Chen, Shuning Gu, Heqing Huang, Guofei Gu, and Jeff Huang. 2025. LLMs in Software Security: A Survey of Vulnerability Detection Techniques and Insights. *ACM Comput. Surv.* 58, 5, Article 134 (Nov. 2025), 35 pages. doi:10.1145/3769082

[31] Benjamin Steenhoek, Md Mahbubur Rahman, Richard Jiles, and Wei Le. 2023. An Empirical Study of Deep Learning Models for Vulnerability Detection. In *Proceedings of the 45th International Conference on Software Engineering* (Melbourne, Victoria, Australia) *(ICSE '23)*. IEEE Press, 2237–2248. doi:10.1109/ICSE48619.2023.00188

[32] Karl Tamberg and Hayretdin Bahsi. 2025. Harnessing Large Language Models for Software Vulnerability Detection: A Comprehensive Benchmarking Study. *IEEE Access* 13 (2025), 29698–29717. doi:10.1109/ACCESS.2025.3541146

[33] Zixuan Tan, Jiayuan Zhou, Xing Hu, Shengyi Pan, Kui Liu, and Xin Xia. 2025. Similar but Patched Code Considered Harmful: The Impact of Similar but Patched Code on Recurring Vulnerability Detection and How to Remove Them. In *2025 IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. 2445–2457. doi:10.1109/ICSE55347.2025.00110

[34] Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Coskun, and Gianluca Stringhini. 2024. LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks. In *2024 IEEE Symposium on Security and Privacy (SP)*. 862–880. doi:10.1109/SP54263.2024.00210

[35] David Wan, Justin Chen, Elias Stengel-Eskin, and Mohit Bansal. 2025. MAMM-Refine: A Recipe for Improving Faithfulness in Generation with Multi-Agent Collaboration. In *Proceedings of the 2025 Conference of the Nations of the Americas Chapter of the Association for Computational Linguistics: Human Language Technologies (Volume 1: Long Papers)*, Luis Chiruzzo, Alan Ritter, and Lu Wang (Eds.). Association for Computational Linguistics, Albuquerque, New Mexico, 9882–9901. doi:10.18653/v1/2025.naacl-long.498

[36] Junhong Wan, Tao Yu, Kunyu Jiang, Yao Fu, Weihao Jiang, and Jiang Zhu. 2025. Digest the Knowledge: Large Language Models empowered Message Passing for Knowledge Graph Question Answering. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Wanxiang Che, Joyce Nabende, Ekaterina Shutova, and Mohammad Taher Pilehvar (Eds.).

Association for Computational Linguistics, Vienna, Austria, 15426–15442. doi:10.18653/v1/2025.acl-long.750

[37] Nengbo Wang, Xiaotian Han, Jagdip Singh, Jing Ma, and Vipin Chaudhary. 2025. CausalRAG: Integrating Causal Graphs into Retrieval-Augmented Generation. In *Findings of the Association for Computational Linguistics: ACL 2025*, Wanxiang Che, Joyce Nabende, Ekaterina Shutova, and Mohammad Taher Pilehvar (Eds.). Association for Computational Linguistics, Vienna, Austria, 22680–22693. doi:10.18653/v1/2025.findings-acl.1165

[38] Ratnadira Widyasari, Martin Weyssow, Ivana Clairine Irsan, Han Wei Ang, Frank Liauw, Eng Lieh Ouh, Lwin Khin Shar, Hong Jin Kang, and David Lo. 2025. Let the trial begin: A mock-court approach to vulnerability detection using llm-based agents. *arXiv preprint arXiv:2505.10961* (2025).

[39] Bozhi Wu, Chengjie Liu, Zhiming Li, Yushi Cao, Jun Sun, and Shang-Wei Lin. 2025. Enhancing Vulnerability Detection via Inter-procedural Semantic Completion. *Proc. ACM Softw. Eng.* 2, ISSTA, Article ISSTA037 (June 2025), 23 pages. doi:10.1145/3728912

[40] Zibin Zheng, Kaiwen Ning, Yanlin Wang, Jingwen Zhang, Dewu Zheng, Mingxi Ye, and Jiachi Chen. 2023. A survey of large language models for code: Evolution, benchmarking, and future trends. *arXiv preprint arXiv:2311.10372* (2023).

[41] Xin Zhou, Sicong Cao, Xiaobing Sun, and David Lo. 2025. Large Language Model for Vulnerability Detection and Repair: Literature Review and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* 34, 5, Article 145 (May 2025), 31 pages. doi:10.1145/3708522

[42] Deqing Zou, Sujuan Wang, Shouhuai Xu, Zhen Li, and Hai Jin. 2021. VulDeePecker: A Deep Learning-Based System for Multiclass Vulnerability Detection. *IEEE Transactions on Dependable and Secure Computing* 18, 05 (Sept. 2021), 2224–2236. doi:10.1109/TDSC.2019.2942930

[43] Deqing Zou, Yawei Zhu, Shouhuai Xu, Zhen Li, Hai Jin, and Hengkai Ye. 2021. Interpreting Deep Learning-based Vulnerability Detector Predictions Based on Heuristic Searching. *ACM Trans. Softw. Eng. Methodol.* 30, 2, Article 23 (March 2021), 31 pages. doi:10.1145/3429444